CloudNova Solutions

Ransomware Incident Response Playbook

Prepared By: Innocent Utu
Role: Junior Cybersecurity Analyst
Incident Type: Ransomware / Suspected Multi-Host Compromise
Organization: CloudNova Solutions
Date: August 9, 2026
Classification: Internal Use

---

1. Executive Summary

CloudNova Solutions is experiencing a major ransomware incident affecting its cloud infrastructure and more than 70 customers. The incident was detected at approximately 7:30 a.m. Monday after system administrators observed abnormal file encryption activity across virtual machines in two data centers. Shortly afterward, customers began reporting that they could no longer access their cloud-hosted resources.

A ransom note subsequently appeared on administrator dashboards demanding 15 Bitcoin in exchange for a decryption key. The attackers identified themselves as "DarkCipher," a ransomware-as-a-service group.

Initial investigation indicates two important attack vectors: a phishing email containing a malicious macro-enabled Excel document was sent to a systems engineer, while an unpatched vulnerability in a third-party monitoring tool running on several virtual hosts was exploited to obtain or expand access.

Because CloudNova operates an IaaS platform, the incident has the potential to affect both internal infrastructure and customer workloads. The immediate priorities are therefore to contain the ransomware, protect unaffected systems, preserve forensic evidence, maintain availability of critical services, determine the scope of compromise, and communicate appropriately with affected customers and legal/regulatory stakeholders.

This playbook provides a structured response based on the NIST incident-response lifecycle, adapted specifically for CloudNova's ransomware scenario.

---

2. Incident Classification

Category	Assessment
Incident Type	Ransomware

Category	Assessment
Severity	**Critical**
Detection Time	7:30 a.m. Monday
Primary Impact	File encryption and service disruption
Affected Environment	Virtual machines across two data centers
Customers Reporting Impact	70+
Suspected Initial Access	Phishing email / malicious Excel document
Additional Attack Vector	Unpatched third-party monitoring tool
Threat Actor	"DarkCipher"
Ransom Demand	15 Bitcoin
Primary Business Risk	Customer downtime, data loss, operational disruption, reputational damage
Response Team	CISO, System Administrators, Legal Counsel, Customer Relations

3. Key Facts and Initial Assessment

3.1 Confirmed Scenario Facts

The following facts were identified from the incident scenario:

- CloudNova Solutions is a mid-sized cloud service provider.
- The company provides Infrastructure-as-a-Service (IaaS).
- CloudNova operates two data centers.
- More than 150 clients depend on the platform.
- More than 70 clients have reported downtime.
- Abnormal file encryption was observed across multiple virtual machines.
- The incident was detected at approximately 7:30 a.m. Monday.
- A ransom note appeared on administrator dashboards.
- The ransom demand is 15 Bitcoin.
- The attackers identify themselves as "DarkCipher."
- Initial access is believed to involve a phishing email.
- The phishing email targeted a systems engineer.
- The email contained a malicious macro-enabled Excel document.
- An unpatched vulnerability exists in a third-party monitoring tool.
- Several virtual hosts were running the vulnerable monitoring tool.
- Ransomware encrypted files on affected virtual machines.

- The incident affects both infrastructure and customers.
- The response team includes the CISO, system administrators, legal counsel, and customer relations.

3.2 Deeper Security Implications

The incident suggests that CloudNova may be dealing with more than a single compromised workstation.

The presence of encryption across multiple virtual machines indicates possible lateral movement, compromised administrative credentials, exploitation of shared infrastructure, or abuse of management systems.

The vulnerable monitoring tool is particularly significant because monitoring infrastructure may have privileged access to multiple hosts. If the attacker exploited the monitoring platform, compromise could potentially spread beyond the originally affected system.

Because CloudNova is an IaaS provider, customer isolation is also a major concern. The response must determine whether ransomware activity crossed tenant boundaries or remained within specific customer environments.

---

4. Incident Response Objectives

The response team should prioritize the following objectives:

1. Protect human safety and critical business operations.
2. Stop the ransomware from continuing to spread.
3. Isolate compromised systems.
4. Protect unaffected customer environments.
5. Preserve forensic evidence.
6. Identify the initial access vector.
7. Determine the full scope of compromise.
8. Remove attacker persistence and malicious components.
9. Patch the exploited vulnerability.
10. Restore affected systems from trusted backups.
11. Verify restored systems before returning them to production.
12. Communicate accurately with affected customers.
13. Meet legal, contractual, and regulatory obligations.
14. Conduct a post-incident review and improve defenses.

---

5. Incident Response Framework

This playbook follows the **NIST incident-response lifecycle**, organized around:

1. Preparation
2. Detection and Analysis
3. Containment, Eradication, and Recovery
4. Post-Incident Activity

The approach is adapted to CloudNova's IaaS environment and ransomware scenario.

---

6. Phase 1 — Preparation

Preparation occurs before an incident but should also be reviewed during and after the current incident.

Required Preparation Activities

Asset Management

Maintain an accurate inventory of:

- Virtual machines
- Hypervisors
- Monitoring servers
- Management interfaces
- Customer environments
- Backup infrastructure
- Network devices
- Administrative accounts
- Security tools

Systems should be classified according to business and customer criticality.

Backup Strategy

CloudNova should maintain:

- Regular offline backups
- Immutable backups where possible
- Separate backup credentials
- Multiple backup copies
- Regular restoration testing

Backups must be protected from ransomware so that attackers cannot encrypt or delete all recovery copies.

Vulnerability Management

The vulnerable third-party monitoring tool should be included in vulnerability-management processes.

CloudNova should establish:

- Patch-management procedures
- Vulnerability scanning
- Emergency patch procedures for critical vulnerabilities
- Software inventory
- End-of-life software tracking

Security Awareness

Employees, especially privileged users and system administrators, should receive regular phishing-awareness training.

Macro-enabled Office documents received from untrusted sources should be treated as high-risk.

Logging and Monitoring

CloudNova should maintain centralized logging for:

- Authentication
- Administrative actions
- Virtual machine activity
- Network connections
- Monitoring systems
- Endpoint security events
- Cloud management interfaces

Logs should be protected from unauthorized modification.

---

7. Phase 2 — Detection and Analysis

7.1 Initial Indicators

The following indicators triggered the incident response:

- Abnormal file encryption.
- Multiple virtual machines becoming unavailable.
- Customer reports of service disruption.
- Ransom notes appearing on administrator dashboards.
- Evidence of exploitation involving the monitoring tool.
- Suspicious phishing activity involving a systems engineer.

7.2 Immediate Analysis Questions

The response team should determine:

- Which systems are encrypted?
- Which systems are still operating normally?
- Which data centers are affected?
- Which customers are affected?
- Did encryption cross customer boundaries?
- Was the monitoring tool exploited?
- Which account was compromised?
- Was the phishing document opened?
- What credentials may have been exposed?
- Is there evidence of lateral movement?
- Are backups accessible?
- Were backups encrypted or deleted?
- Does the attacker still have active access?
- Was data exfiltrated before encryption?

7.3 Evidence Collection

Investigators should preserve:

- Authentication logs
- VPN logs
- Firewall logs
- Monitoring-tool logs
- Endpoint logs
- Email security logs
- EDR alerts
- Virtual machine logs
- Hypervisor logs
- Cloud management logs
- Ransom notes
- Malicious Excel document
- Relevant network traffic
- File-system metadata

Investigators should avoid unnecessarily modifying compromised systems because doing so could destroy useful forensic evidence.

---

8. Phase 3 — Containment

Containment is the highest immediate priority because ransomware may continue spreading.

8.1 Short-Term Containment

The response team should:

1. Isolate confirmed compromised virtual machines.
2. Disconnect affected systems from unnecessary network segments.
3. Restrict communication between affected and unaffected environments.
4. Disable compromised user accounts.
5. Reset credentials associated with suspected compromise.
6. Restrict access to the vulnerable monitoring tool.
7. Disable unnecessary services.
8. Block known malicious indicators at network security controls.
9. Protect backup infrastructure from affected networks.
10. Increase monitoring for additional ransomware activity.

8.2 Protecting the Two Data Centers

Because both data centers are potentially affected, containment should be coordinated across both locations.

CloudNova should identify:

- Which data center was compromised first.
- Whether the attack moved between data centers.
- Whether shared management infrastructure connects both locations.
- Whether common administrative credentials were used.

If a shared management system is compromised, simply isolating individual virtual machines may not be sufficient.

8.3 Customer Isolation

Because CloudNova provides IaaS services, affected customer environments should be logically isolated from unaffected tenants.

The response team should verify:

- Tenant separation.
- Virtual network boundaries.
- Storage permissions.
- Administrative access.
- Management-plane access.
- Shared infrastructure dependencies.

---

9. Ransomware-Specific Containment Priorities

The following actions should be treated as high priority:

Priority 1 — Stop Active Encryption

Identify and isolate machines where encryption is actively occurring.

Priority 2 — Protect Backups

Immediately restrict access to backup systems and verify whether backups remain intact.

Priority 3 — Protect Management Infrastructure

Secure:

- Hypervisors
- Cloud management consoles
- Monitoring systems
- Identity systems
- Administrative jump hosts

Priority 4 — Prevent Credential Reuse

Reset potentially compromised administrative credentials and invalidate active sessions where appropriate.

Priority 5 — Block the Exploited Vulnerability

Remove, patch, isolate, or disable the vulnerable third-party monitoring tool.

---

10. Phase 3 — Eradication

Once active ransomware spread has been contained, the team should remove the underlying causes of compromise.

10.1 Remove Malware

Affected systems should be rebuilt or restored from trusted sources rather than assuming that deleting visible ransomware files is sufficient.

10.2 Patch the Monitoring Tool

The vulnerable third-party monitoring tool must be:

- Patched to a supported secure version.
- Removed if no secure version exists.
- Isolated from unnecessary networks.
- Restricted to required administrative access.

10.3 Address the Phishing Vector

The malicious Excel document should be collected and analyzed safely.

The security team should determine:

- Who received it.
- Who opened it.
- What processes it launched.
- What network connections it created.
- Whether credentials were exposed.
- Whether additional users received the same campaign.

The malicious document should be quarantined from organizational email systems.

10.4 Credential Remediation

Potentially compromised credentials should be reset, prioritizing:

- Systems administrators
- Cloud administrators
- Monitoring-tool accounts
- Service accounts
- VPN users
- Privileged accounts

Multi-factor authentication should be enabled wherever technically feasible.

---

11. Phase 3 — Recovery

Recovery should occur in controlled stages.

11.1 Restore from Trusted Backups

CloudNova should identify the most recent known-good backups and verify their integrity before restoration.

Restoration should prioritize:

1. Core identity and security services.
2. Management infrastructure.
3. Critical cloud platform components.
4. Highest-priority customer workloads.
5. Remaining customer systems.

11.2 Validate Restored Systems

Before returning systems to production, administrators should verify:

- Malware is absent.
- Vulnerabilities are patched.
- Administrative credentials have been reset.
- Logging is operational.
- Network controls are functioning.
- Backup connectivity is secure.
- Monitoring is active.

11.3 Gradual Restoration

Systems should not all be restored simultaneously.

A phased recovery approach allows the team to identify reinfection or persistence before the entire environment is brought back online.

---

12. Communication Plan

Communication must be coordinated through designated personnel.

Internal Communication

The CISO should provide regular updates to:

- Executive leadership
- System administrators
- Legal counsel
- Customer relations

- Relevant security personnel

Incident information should be shared on a need-to-know basis.

Customer Communication

Customer Relations should provide affected customers with:

- Confirmation of service disruption where appropriate.
- Current service status.
- Actions being taken.
- Expected recovery information when known.
- Recommended customer actions.
- A dedicated communication channel for incident-related questions.

The organization should avoid making unsupported claims about the attacker's identity, data theft, or recovery timeline.

Legal and Regulatory Communication

Legal Counsel should determine:

- Contractual notification obligations.
- Data-breach notification requirements.
- Regulatory reporting requirements.
- Law-enforcement notification.
- Requirements associated with affected customer data.

---

13. Roles and Responsibilities

CISO

Primary responsibility: Overall incident command.

Responsibilities:

- Declare and classify the incident.
- Coordinate the incident response team.
- Approve major containment decisions.
- Coordinate with executive leadership.
- Establish communication priorities.
- Track incident status.
- Approve recovery decisions.
- Ensure lessons learned are documented.

Why this role is important

The incident affects multiple data centers and more than 70 customers, so centralized decision-making is necessary to prevent conflicting actions.

System Administrators

Primary responsibility: Technical containment, investigation, and recovery.

Responsibilities:

- Identify compromised virtual machines.
- Isolate affected hosts.
- Protect infrastructure.
- Investigate the monitoring-tool vulnerability.
- Apply emergency patches.
- Preserve technical evidence.
- Reset compromised credentials.
- Restore systems.
- Validate recovered systems.
- Monitor for reinfection.

Why this role is important

System administrators have the technical access required to isolate and restore the affected infrastructure.

Legal Counsel

Primary responsibility: Legal, contractual, regulatory, and evidence-handling guidance.

Responsibilities:

- Determine notification obligations.
- Review customer contracts.
- Advise on regulatory requirements.
- Coordinate with law enforcement when appropriate.
- Provide guidance regarding ransom-related decisions.
- Ensure incident documentation is legally appropriate.
- Advise on preservation of evidence.

Why this role is important

CloudNova handles infrastructure for more than 150 clients, creating potentially significant contractual and regulatory obligations.

Customer Relations

Primary responsibility: Customer communication and support.

Responsibilities:

- Maintain communication with affected customers.
- Provide approved incident updates.
- Track customer impact.
- Escalate critical customer issues.
- Coordinate service restoration notifications.
- Avoid releasing unverified technical information.

Why this role is important

More than 70 customers have reported downtime, making customer communication a major component of incident management.

---

14. Incident Response Timeline

Time/Stage	Action
7:30 a.m.	Abnormal encryption detected
Shortly afterward	Customer downtime reports received
Initial response	Incident escalated to CISO
Immediate	Identify and isolate affected systems
Immediate	Protect backup infrastructure
Investigation	Analyze phishing and monitoring-tool indicators
Containment	Restrict compromised accounts and systems
Eradication	Patch or remove vulnerable monitoring tool
Recovery	Restore validated systems from trusted backups
Validation	Monitor restored environments
Customer recovery	Notify customers as services return
Post-incident	Conduct lessons-learned review

---

15. Ransom Demand Decision

The ransom demand is **15 Bitcoin**.

CloudNova should not make an immediate payment decision based solely on operational pressure.

Before considering any response to the ransom demand, leadership and Legal Counsel should evaluate:

- Whether backups can successfully restore operations.
- Whether data was exfiltrated.
- Whether decryption is technically possible.
- Legal and regulatory implications.
- Financial impact of downtime.
- Potential consequences of paying.
- Whether the attacker can be trusted to provide working decryption capability.
- Whether payment could encourage future attacks.

The priority should remain containment, evidence preservation, recovery, and protection of customers.

---

16. Indicators of Compromise to Track

The response team should maintain an incident IOC list containing:

- Ransom note text.
- Ransomware file extensions.
- Suspicious file hashes.
- Malicious Excel document hash.
- Malicious email sender information.
- Suspicious domains.
- Suspicious IP addresses.
- Compromised usernames.
- Abnormal authentication events.
- Monitoring-tool exploitation indicators.
- Unusual administrative activity.
- Processes associated with encryption.

These indicators should be shared with appropriate security monitoring systems to identify additional compromised hosts.

---

17. Validation and Recovery Criteria

A system should not be considered recovered until:

- The ransomware has been removed or the system has been rebuilt.
- The original vulnerability has been remediated.
- Compromised credentials have been addressed.
- Security controls are operational.
- Logs are being collected.
- Backups remain protected.
- No continuing malicious activity is detected.
- Customer functionality has been tested.
- Administrators have approved production restoration.

---

18. Post-Incident Activities

After recovery, CloudNova should conduct a formal lessons-learned review.

The review should answer:

1. How did the phishing attack bypass existing controls?
2. Why was the monitoring vulnerability unpatched?
3. How did the attacker move from initial access to multiple virtual machines?
4. Were privileged credentials compromised?
5. Was customer data accessed or exfiltrated?
6. Why did detection occur after encryption began?
7. Were backups adequately protected?
8. How quickly could services be restored?
9. Were communication procedures effective?
10. What security controls should be improved?

The results should be converted into an improvement plan with assigned owners and deadlines.

---

19. Recommended Security Improvements

Based on this incident, CloudNova should prioritize:

Endpoint and Email Security

- Block or restrict macro-enabled Office documents received from external sources.
- Deploy advanced email filtering.
- Implement phishing-resistant authentication where possible.

- Conduct recurring phishing-awareness training.

Vulnerability Management

- Establish critical vulnerability SLAs.
- Perform continuous vulnerability scanning.
- Maintain a complete software inventory.
- Implement emergency patching procedures.

Privileged Access

- Implement MFA for administrative accounts.
- Apply least privilege.
- Separate administrative and normal user accounts.
- Monitor privileged activity.

Network Segmentation

- Separate customer environments.
- Segment management infrastructure.
- Restrict monitoring-system communication.
- Isolate backup networks.

Backup Security

- Implement immutable backups.
- Maintain offline recovery copies.
- Use separate backup credentials.
- Test restoration regularly.

Detection and Response

- Deploy centralized logging.
- Improve ransomware behavior detection.
- Monitor unusual file-encryption activity.
- Alert on suspicious administrative actions.
- Conduct regular incident-response exercises.

---

20. Playbook Decision Flow

Suspicious encryption detected

↓

Declare suspected ransomware incident

↓

Activate CISO and incident response team

↓

Identify affected systems

↓

Isolate compromised hosts

↓

Protect backup and management infrastructure

↓

Investigate initial access and lateral movement

↓

Patch/remove vulnerable monitoring tool

↓

Reset compromised credentials

↓

Determine whether data was exfiltrated

↓

Validate trusted backups

↓

Rebuild/restore affected systems

↓

Security validation

↓

Gradual return to production

↓

Customer communication

↓

Post-incident review

↓

Security improvements

---

21. Framework Alignment

This playbook is primarily aligned with the **NIST incident-response lifecycle**.

The four major areas are:

Preparation

CloudNova prepares through asset management, backups, vulnerability management, security awareness, logging, and incident-response planning.

Detection and Analysis

The organization identifies ransomware indicators, analyzes logs, determines scope, and investigates the phishing and vulnerable monitoring-tool vectors.

Containment, Eradication, and Recovery

The organization isolates compromised systems, protects backups, removes the attacker's access, patches the vulnerable software, resets credentials, and restores trusted systems.

Post-Incident Activity

CloudNova documents lessons learned, identifies control failures, improves defenses, and updates the incident-response plan.

The playbook also reflects commonly used incident-response principles such as evidence preservation, containment, eradication, recovery, communication, and continuous improvement.

---

22. Final Assessment

The CloudNova incident represents a **critical ransomware event** because it affects infrastructure across two data centers and has already caused downtime for more than 70 customers.

The combination of a phishing attack and an unpatched vulnerability indicates that the incident may involve multiple stages of compromise. The presence of ransomware on multiple virtual machines also means that CloudNova must investigate potential lateral movement and determine whether shared management infrastructure or privileged credentials were compromised.

The immediate priority should be to stop active encryption and prevent further spread while protecting backups and preserving forensic evidence. The vulnerable third-party monitoring tool must be patched or removed, and potentially compromised credentials must be addressed.

Recovery should be based on verified trusted backups and performed in controlled stages. Customer communication should remain accurate and coordinated through Customer Relations and Legal Counsel.

Following the incident, CloudNova should strengthen vulnerability management, phishing defenses, network segmentation, privileged access controls, backup protection, and ransomware detection.

The incident demonstrates that effective incident response is not limited to removing malware. A successful response must protect customers, preserve evidence, maintain business continuity, identify the root cause, restore trustworthy services, and ensure that the same attack path cannot be easily reused.

---

23. Immediate Incident Checklist

First Priority

- [ ] Activate incident response team.
- [ ] Declare ransomware incident.
- [ ] Isolate actively encrypted systems.
- [ ] Protect backup systems.
- [ ] Protect management infrastructure.
- [ ] Disable compromised accounts.
- [ ] Preserve critical evidence.
- [ ] Identify affected customers.
- [ ] Investigate both data centers.

Investigation

- [ ] Analyze phishing email.
- [ ] Preserve malicious Excel document.
- [ ] Investigate monitoring-tool exploitation.
- [ ] Review authentication logs.

- [ ] Review network logs.
- [ ] Identify lateral movement.
- [ ] Determine whether data was exfiltrated.
- [ ] Identify all affected hosts.

Eradication

- [ ] Patch/remove vulnerable monitoring tool.
- [ ] Remove attacker persistence.
- [ ] Reset compromised credentials.
- [ ] Rebuild compromised systems where necessary.
- [ ] Validate security controls.

Recovery

- [ ] Verify backup integrity.
- [ ] Restore critical infrastructure.
- [ ] Test restored systems.
- [ ] Gradually restore customer services.
- [ ] Monitor for reinfection.
- [ ] Confirm service availability.

Post-Incident

- [ ] Conduct lessons-learned meeting.
- [ ] Document root cause.
- [ ] Update security controls.
- [ ] Update IR playbook.
- [ ] Conduct ransomware tabletop exercise.
- [ ] Track remediation actions to completion.

Final Conclusion

CloudNova should treat this event as a critical enterprise and customer-impacting ransomware incident. The combination of phishing, an unpatched third-party application, multi-host encryption, and widespread customer downtime requires coordinated technical, legal, operational, and communication responses.

The most important lesson from this scenario is that ransomware resilience depends on multiple defensive layers. Strong patch management, phishing resistance, network segmentation, privileged-access controls, protected backups, centralized monitoring, and a tested incident-response process must work together.

A mature response should therefore focus not only on recovering from the current attack but also on eliminating the weaknesses that allowed the attack to succeed.